

VindobonaPay GmbH — Control Test Plan

Testing of control design and operating effectiveness | Test period: H1 2026 | Version 1.0 | Fictional company for educational purposes

#	Control (Annex A)	Control objective	Test type	Test procedure	Population	Sample size and rationale	Frequency	Evidence required	Tester
CT-01	A.8.2 / A.8.5 — Privileged access rights and secure authentication	All privileged accounts authenticate with multi-factor authentication using a strong method.	Design + Operating effectiveness	Obtain the list of privileged accounts and the MFA enrollment export. Compare the two and identify accounts without MFA or using a weak method. Automated with a Python script (see repository).	12 privileged accounts	12 (100% — small population, all items tested)	Quarterly	Privileged account list; MFA enrollment export; script output (results and exceptions CSV)	CISO
CT-02	A.8.5 — Secure authentication (all users)	MFA is enforced for all user accounts through conditional access.	Design + Operating effectiveness	Review the conditional access policy configuration. Select a sample of users and verify their MFA registration status.	85 user accounts	15 (sample for a continuously operating control)	Yearly	Conditional access policy export; MFA registration report	IT Manager
CT-03	A.5.18 — Access rights review	Access rights to payment and administrative systems are reviewed and confirmed every quarter.	Design + Operating effectiveness	Confirm that a documented review procedure exists. For the quarters in scope, obtain the review records and verify sign-off and follow-up of removals.	4 quarterly reviews	2 (standard sample for a quarterly control)	Yearly	Access review procedure; review records with reviewer sign-off; evidence of access removals	CISO
CT-04	A.8.13 — Information backup	Backups run as scheduled and restores are tested periodically with documented results.	Operating effectiveness	Obtain the backup job history and the restore test records. Verify that restore tests were performed and that failures were followed up.	4 quarterly restore tests	2 (standard sample for a quarterly control)	Yearly	Backup job history; restore test reports	IT Manager
CT-05	A.6.3 — Security awareness and training	All staff complete security awareness training, and new joiners are trained within 30 days.	Operating effectiveness	Obtain the training completion report and the list of new joiners in the period. Verify completion and timeliness for the sample.	85 employees (18 new joiners)	15 (sample across staff and new joiners)	Yearly	Training completion report; new joiner list; phishing simulation results	HR Manager
CT-06	A.5.11 — Return of assets and access removal on termination	On termination, accounts are disabled and company assets are returned within the defined timeframe.	Operating effectiveness	Obtain the list of leavers in the period. For the sample, compare the termination date with the account disable date and the asset return record.	14 leavers	10 (sample of a low-volume, high-impact control)	Yearly	HR leaver list; account disable logs; offboarding checklists	HR Manager
CT-07	A.8.7 — Protection against malware	Endpoint detection and response is installed, active and reporting on all managed endpoints.	Operating effectiveness	Compare the asset inventory with the EDR console export. Identify devices missing the agent or not reporting within the last 14 days.	92 managed endpoints	92 (100% — full population from system exports)	Quarterly	Asset inventory; EDR console export with last check-in dates	IT Manager
CT-08	A.8.24 / A.7.9 — Encryption of endpoints	Full-disk encryption is enabled on all company laptops.	Operating effectiveness	Export the encryption compliance report from the device management platform and identify non-compliant devices.	92 managed endpoints	92 (100% — full population from system exports)	Quarterly	Device management encryption compliance report	IT Manager

Sample sizes follow common audit practice: for controls operating quarterly a sample of 2 occurrences is tested; for continuously operating or manual controls a sample of 15 items is used; where the population is small or fully available from a system export, 100% is tested.

Test of design asks whether the control, as described, would prevent or detect the risk. Test of operating effectiveness asks whether it actually worked during the period.

Evidence Request List

What is requested, from whom, and for which test. Sent to control owners before testing starts.

#	Evidence	Source system / document	Requested from	Format	Related test
E-01	List of privileged accounts	Identity platform (Entra ID) export	IT Manager	CSV	CT-01
E-02	MFA enrollment report	Identity platform (Entra ID) export	IT Manager	CSV	CT-01, CT-02
E-03	Conditional access policy configuration	Identity platform (Entra ID)	IT Manager	Export / screenshot	CT-02
E-04	Access review procedure	ISMS documentation	CISO	Document	CT-03
E-05	Access review records with sign-off	Ticketing system / shared drive	IT Manager	Document	CT-03
E-06	Backup job history	Cloud backup service	IT Manager	Export	CT-04
E-07	Restore test reports	IT operations records	IT Manager	Document	CT-04
E-08	Training completion report	Awareness training platform	HR Manager	Export	CT-05
E-09	List of new joiners and leavers in the period	HR system	HR Manager	List	CT-05, CT-06
E-10	Account disable logs	Identity platform audit log	IT Manager	Export	CT-06
E-11	Offboarding checklists	HR records	HR Manager	Document	CT-06
E-12	Asset inventory	Device management platform	IT Manager	Export	CT-07, CT-08
E-13	EDR console export with last check-in dates	Endpoint security console	IT Manager	Export	CT-07
E-14	Encryption compliance report	Device management platform	IT Manager	Export	CT-08

Test Results

Outcome of each test, with the number of exceptions found.

#	Control	Population	Sample tested	Exceptions	Conclusion	Notes
CT-01	A.8.2 / A.8.5 — Privileged accounts MFA	12	12	3	Effective with exceptions	Three exceptions: one admin account using SMS (weak method), one service account without MFA, one break-glass account missing from the MFA report. Test executed with the Python script; output retained as evidence.
CT-02	A.8.5 — MFA for all users	85	15	0	Effective	Conditional access policy enforces MFA for all users; all sampled accounts were registered.
CT-03	A.5.18 — Access rights review	4	2	2	Not effective	Design gap: no documented review procedure exists and reviews are performed ad-hoc. Records for the sampled quarters could not be produced. The control cannot be considered effective.
CT-04	A.8.13 — Information backup	4	2	0	Effective	Backup jobs completed as scheduled; restore tests performed and documented for both sampled quarters.
CT-05	A.6.3 — Awareness training	85	15	1	Effective with exceptions	One new joiner completed training 47 days after start date, against the 30-day requirement.
CT-06	A.5.11 — Return of assets and access removal	14	10	1	Effective with exceptions	One leaver account remained enabled for 5 working days after the termination date. Asset return was documented for all sampled leavers.
CT-07	A.8.7 — Malware protection coverage	92	92	3	Effective with exceptions	Three endpoints had not reported to the EDR console within 14 days. All three were laptops of staff on extended leave.
CT-08	A.8.24 / A.7.9 — Endpoint encryption	92	92	0	Effective	All managed endpoints reported encryption enabled.

Conclusion:

- Effective
- Effective with exceptions
- Not effective

CT-01 was executed with a Python script (mfa_privileged_check.py in this repository). The script output is retained as evidence and the test can be re-run at any time with the same result.

Exceptions and Remediation

Every exception is recorded with its root cause, remediation, owner and target date, and linked to the Risk Register.

#	Test	Exception description	Severity	Root cause	Remediation	Owner	Target	Related risk
X-01	CT-01	Admin account adm.tmayer uses SMS as MFA method, which is not accepted for privileged access.	Medium	The MFA policy does not specify which methods are acceptable for privileged accounts.	Define accepted MFA methods for privileged accounts and re-enroll the account on an authenticator app or FIDO2 key.	IT Manager	Q3 2026	R-02
X-02	CT-01	Service account svc.backup has no MFA enabled.	High	Service accounts were excluded from the MFA rollout without a documented compensating control.	Migrate the account to a managed identity, or document a compensating control (restricted source IP, credential rotation) and formally accept the residual risk.	IT Manager	Q3 2026	R-02
X-03	CT-01	Break-glass account brk.emergency does not appear in the MFA enrollment report.	High	The account was created outside the standard provisioning process and is not covered by the reporting scope.	Bring the account into the identity governance scope, apply MFA and document the break-glass procedure with monitoring of its use.	CISO	Q3 2026	R-02
X-04	CT-03	No documented access review procedure; quarterly reviews are performed ad-hoc and without records.	High	Access reviews were introduced informally and never formalized into a procedure with evidence requirements.	Define the quarterly access review procedure, assign reviewers and retain signed records.	CISO	Q4 2026	R-02, R-08
X-05	CT-05	One new joiner completed awareness training 47 days after start date (requirement: 30 days).	Low	Training assignment is manual and was not triggered at onboarding.	Add training assignment to the onboarding checklist and monitor completion monthly.	HR Manager	Q3 2026	R-03
X-06	CT-06	One leaver account remained enabled for 5 working days after the termination date.	Medium	Account disabling depends on a manual notification from HR to IT.	Trigger account disabling from the HR termination record and verify within 24 hours.	IT Manager	Q4 2026	R-08
X-07	CT-07	Three endpoints had not reported to the EDR console within 14 days.	Low	No alerting on stale EDR agents; devices belonged to staff on extended leave.	Configure an alert for endpoints not reporting for more than 14 days and define a follow-up process.	IT Manager	Q4 2026	R-04

Exceptions are not closed by the tester: each one is remediated by the control owner, or formally accepted by management with a documented rationale, as for the accepted risks in Deliverable 02.

Control Testing — Summary

Values calculated automatically from the test results and exceptions sheets.

Controls tested	8
-----------------	---

BY CONCLUSION

Effective	3
Effective with exceptions	4
Not effective	1

EXCEPTIONS BY SEVERITY

High	3
Medium	2
Low	2
Total exceptions	7

The three High exceptions all relate to privileged access (R-02), which is the highest residual risk in the Risk Register. Testing confirmed the risk assessment rather than contradicting it.

CT-03 failed at design stage: the control was described as quarterly in the SoA but no procedure or records exist. This is why the SoA marks A.5.18 as partially implemented.